

Mapeo de Preguntas a Requisitos Normativos y Marcos de Referencia

La siguiente tabla relaciona cada bloque y pregunta de la encuesta con marcos y requisitos normativos habituales (NIS2, ENS, ISO 27001, RGPD donde aplica, y marcos técnicos como MITRE ATT&CK). El objetivo es facilitar su uso en contextos de cumplimiento y auditoría, sin perder el enfoque práctico en la Pirámide del Dolor.

Nota: Las referencias normativas son indicativas y deben adaptarse a la versión específica y al contexto sectorial de cada organización.

Bloque / Pregunta	Tema principal	NIS2 / Directivas UE	ENS / Normativa española	ISO / Otros estándares	Marcos técnicos (ATT&CK, etc.)	Comentario de uso
1.1 - 1.5	Contexto organizativo, rol, tamaño, SOC	Art. 21 (gestión de riesgos), Anexo obligaciones de operadores esenciales	ENS – Organización y marco operacional	ISO 27001 – Cláus. 4 (contexto), 5 (liderazgo)	N/A	Ayuda a segmentar resultados por criticidad y recursos disponibles
2.1 - 2.4	Conocimiento y uso de la Pirámide del Dolor	Art. 20 (cultura de seguridad)	ENS – OP.1 (organización de la seguridad)	ISO 27001 – Cláus. 7 (competencia, concienciación)	Relación conceptual con ATT&CK	Mide si la Pirámide se integra como marco conceptual y operativo
3.1 - 3.4	Gestión de hashes maliciosos	Art. 21 (técnicas de detección), Anexo medidas técnicas	ENS – PR.1, PR.2 (protección)	ISO 27001 – Anexo A.8 (gestión de activos), A.12 (operaciones)	IoC de bajo nivel, STIX/TAXII	Evalúa prácticas en la base de la Pirámide (IoC efímeros)
3.5 - 3.8	Gestión de IPs y dominios maliciosos	Ídem	ENS – OP.2, OP.3 (operación segura)	ISO 27001 – A.13 (seguridad en comunicaciones)	Blacklists, reputación, threat intelligence	Destaca la importancia de caducidad y recertificación de listas
4.1 - 4.6	Artefactos de red y host, reglas de detección	Art. 21 (detección y prevención de incidentes)	ENS – OP.3 (detección), OP.4 (respuesta)	ISO 27001 – A.12, A.16 (gestión de incidentes)	NDR, EDR/XDR, NIDS/HIDS	Se alinea con el nivel intermedio de la Pirámide: patrones y artefactos
5.1 - 5.4	Uso de MITRE ATT&CK, técnicas observadas	NIS2 – Gestión de riesgos avanzados	ENS – MP.2 (mejora continua)	ISO 27001 – Cláus. 9 (evaluación del desempeño)	MITRE ATT&CK, D3FEND	Mide la formalización de TTP como lenguaje común de detección

5.5 – 5.7	Mapeo a niveles de Pirámide, esfuerzo por nivel	Ídem	ENS – OP.3, MP.2	ISO 27001 – Mejora de controles	ATT&CK, modelos de robustez analítica	Refuerza el enfoque de priorizar detecciones de alto nivel
6.1 – 6.4	MTTD, MTTR, eficacia de detección	NIS2 – Obligaciones de notificación y gestión de incidentes	ENS – OP.4 (respuesta a incidentes), MP.2	ISO 27001 – A.16 (gestión de incidentes), métricas	Buenas prácticas de SOC	Conecta métricas clásicas con niveles de la Pirámide
6.5 – 6.7	Falsos positivos, ruido, “dolor infligido”	NIS2 – Gestión eficaz de incidentes	ENS – eficiencia de controles	ISO 27004 (medición de la seguridad)	ATT&CK (detecciones de alta fidelidad)	Ayuda a justificar ajustes de reglas y priorización por impacto
7.1 – 7.5	Intercambio de información, coordinación nacional	NIS2 – Cooperación y notificación, CSIRTs	ENS – CO.1 (cooperación), OP.5	ISO 27010 (intercambio o inter-organizativo)	Plataformas de CTI, ISACs	Evalúa el grado de integración en ecosistemas de intercambio
8.1 – 8.4	Marcos normativos, reportes al Consejo	NIS2 – Gobernanza, responsabilidad de la dirección	ENS – Organización y responsabilidades	ISO 27001 – Cláus. 5, 9 (dirección y reporting)	ATT&CK como lenguaje para comunicar riesgo táctico	Refuerza la necesidad de narrativa comprensible para alta dirección
9.1 – 9.4	Obstáculos, prioridades, visión futura	NIS2 – Planificación estratégica	ENS – Mejora continua	ISO 27001 – Cláus. 10 (mejora)	Roadmaps ATT&CK, Zero Trust	Apoya la definición de planes de acción y prioridades

Sugerencia: este mapeo puede ampliarse añadiendo columnas específicas para cada sector (salud, energía, financiero), indicando referencias sectoriales adicionales (p. ej., DORA, NERC CIP, NIS sectorial).